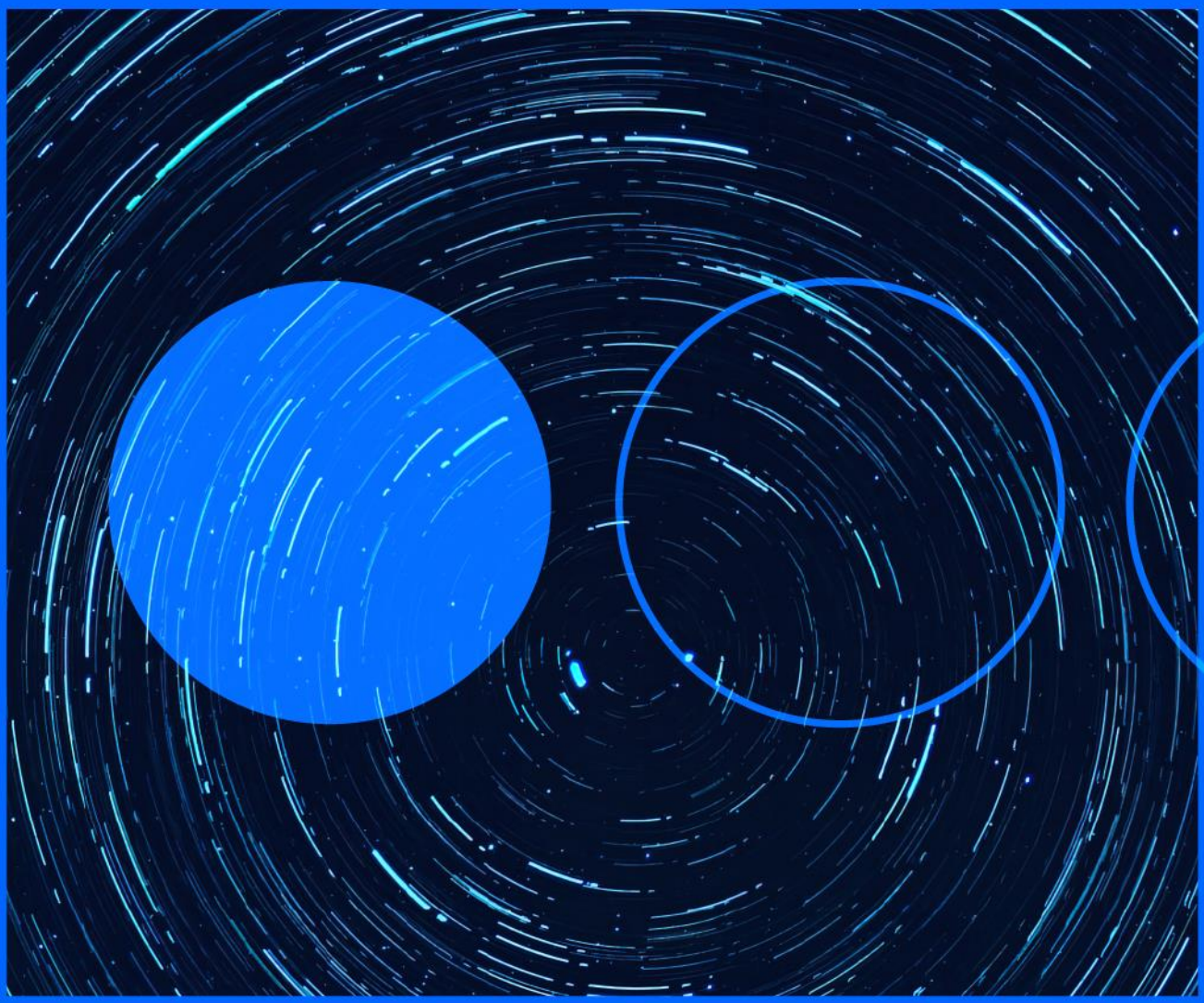
Telefónica Tech

28.07.2023

Boletín semanal de ciberseguridad 2023



telefonicatech.com

Resumen de los principales ataques y vulnerabilidades encontradas por nuestros expertos durante la primera semana del año.

Los iconos responden a los siguientes conceptos.

Ciberoperaciones	Incidentes	Malware	Fugas de Información	Vulnerabilidades

Campaña de ransomware Cl0p explotando vulnerabilidad en MOVEit

El pasado 31 de mayo de 2023, Progress Software publicó un parche para la vulnerabilidad crítica de inyección SQL que podría permitir a los atacantes obtener el control total de un equipo que contuviera el software MOVEit. En concreto, este fallo de seguridad registrado como CVE-2023-34362, CVSSv3 9.8, se consideró una 0-day debido a que antes de su parche se identificó activamente su explotación. Días después, Microsoft atribuyó a operadores de ransomware Cl0p la autoría de una campaña de aprovechamiento de esta vulnerabilidad. Desde entonces el número de víctimas, según Konbriefing, se ha ido incrementando, siendo actualmente 522 organizaciones repartidas en multitud de sectores a nivel global, incluyendo empresas de consultoría, tecnología o retail entre otras, siendo EE.UU. el país con más afectación. En base a estos hechos, Ryan McConechy, CTO de Barrier Networks, declaraba al medio digital Spiceworks que las autoridades recomiendan a las entidades no negociar con los atacantes.

URL: https://www.spiceworks.com/it-security/security-general/articles/moveit-vulnerability-impact-victims/

Vulnerabilidad crítica en routers MikroTik

Investigadores de VulnCheck informaron que una falla crítica de elevación de privilegios en routers MikroTik RouterOS representa un riesgo importante para más de 900.000 dispositivos. La vulnerabilidad, identificada como CVE-2023-30799 (CVSS 9.1) permite a actores de amenaza remotos con cuentas de administrador existentes obtener el nivel de super-admin a través de la interfaz HTTP o Winbox del dispositivo. Aunque se requieren credenciales válidas, el sistema no está protegido contra ataques de fuerza bruta debido a un usuario admin predeterminado conocido. La vulnerabilidad fue originalmente revelada en junio de 2022 como un exploit denominado FOISted sin un identificador CVE. Sin embargo, no se parcheó por completo hasta julio de 2023 para versión 6.49.8. Una PoC desarrollada por VulnCheck demostró que es posible controlar el sistema operativo RouterOS, obtener acceso de super-admin a través de una simple escalada de privilegios, y ocultar actividades. MikroTik recomienda aplicar la última actualización, eliminar interfaces administrativas de Internet, restringir direcciones IP de inicio de sesión, deshabilitar Winbox y usar solo SSH con claves públicas/privadas para mitigar la vulnerabilidad.

URL: https://vulncheck.com/blog/mikrotik-foisted-revisited

2023 © Telefónica Cybersecurity & Cloud Tech S.L.U. Todos los derechos reservados.

Descubiertos 15.000 servidores Citrix expuestos a ataques RCE

Investigadores de la organización sin ánimo de lucro Shadowserver Foundation han alertado de que una búsqueda en fuentes abiertas revela que en la actualidad hay al menos 15.000 servidores Citrix expuestos a la vulnerabilidad CVE-2023-3519, CVSSv3 de 9.8, que podría ser aprovechada por un actor amenaza para ejecutar código de forma remota sin autenticación. Cabe indicar que para explotar esta vulnerabilidad se requiere que el dispositivo vulnerable este configurado como una puerta de enlace o como un servidor virtual de autenticación. Shadowserver indica que estos equipos Citrix Netscaler ADC y Citrix Gateway aparecen con una última fecha de actualización previa a la publicación del parche, por lo que asumen que están expuestos. Por otra parte, CISA advirtió de que una infraestructura crítica en Estados Unidos fue atacada recientemente mediante la explotación del 0-day de esta vulnerabilidad.

URL: https://twitter.com/Shadowserver/status/1682355280317919233

Actualización de seguridad de Apple para un nuevo 0-day

Apple ha publicado una nueva actualización de seguridad para iOS, iPadOS, macOS, tvOS, watchOS y Safari para solucionar una vulnerabilidad 0-day de la que tiene constancia que ha sido explotada en ataques recientes contra versiones de iOS lanzadas antes de iOS 15.7.1. La vulnerabilidad ha sido catalogada como CVE-2023-38606, aún no se ha asignado CVSS, y permite que una aplicación maliciosa modifique potencialmente el estado del kernel. CVE-2023-38606 es la tercera vulnerabilidad relacionada con la llamada Operation Triangulation, un ataque zero-click (la recepción del mensaje desencadena la infección sin necesidad de interacción del usuario) contra dispositivos iOS a través de iMessage. Las otras dos 0-days, CVE-2023-32434 y CVE-2023-32435, ya habían sido parcheadas por Apple.

URL: https://twitter.com/Shadowserver/status/1682355280317919233

Vulnerabilidad en CPUs AMD Zen2 permite robar datos confidenciales

El investigador de seguridad de Google Tavis Ormandy descubrió una nueva vulnerabilidad que afecta a las CPUs AMD Zen2 y que podría permitir a un actor de amenaza robar datos confidenciales, como contraseñas y claves de cifrado, a una velocidad de 30 KB/s de cada núcleo de la CPU. La vulnerabilidad se ha clasificado como CVE-2023-20593 y está causada por el manejo inadecuado de una instrucción llamada 'vzeroupper' durante la ejecución, una técnica común de mejora del rendimiento utilizada en todos los procesadores modernos. Tras activar un exploit optimizado para la vulnerabilidad, un actor de amenaza podría filtrar datos confidenciales de cualquier operación del sistema, incluidas las que tienen lugar en máquinas virtuales, sandboxes aislados, contenedores, etc. El investigador de Google ha publicado una PoC para explotar la vulnerabilidad.

URL: https://lock.cmpxchg8b.com/zenbleed.html

2023 © Telefónica Cybersecurity & Cloud Tech S.L.U. Todos los derechos reservados.

Sobre Telefónica Tech

Telefónica Tech es la compañía líder en transformación digital. La compañía cuenta con una amplia oferta de servicios y soluciones tecnológicas integradas de Ciberseguridad, Cloud, IoT, Big Data o Blockchain.

Más información

telefonicatech.com

2023 © Telefónica Cybersecurity & Cloud Tech S.L.U. Todos los derechos reservados.

La información contenida en el presente documento es propiedad de Telefónica Cybersecurity & Cloud Tech S.L.U. (en adelante "Telefónica Tech") y/o de cualquier otra entidad dentro del Grupo Telefónica o sus licenciantes.
Telefónica Tech y/o cualquier compañía del Grupo Telefónica o los licenciantes de Telefónica Tech se reservan todos los derechos de propiedad industrial e intelectual (incluida cualquier patente o copyright) que se deriven o recaigan sobre este documento, incluidos los derechos de diseño, producción, reproducción, uso y venta del mismo, salvo en el supuesto de que dichos derechos sean expresamente conferidos a terceros por escrito. La información contenida en el presente documento podrá ser objeto de modificación en cualquier momento sin necesidad de previo aviso.
La información contenida en el presente documento no podrá ser ni parcial ni totalmente copiada, distribuida, adaptada o reproducida en ningún soporte sin que medie el previo consentimiento por escrito por parte de Telefónica Tech.
El presente documento tiene como único objetivo servir de soporte a su lector en el uso del producto, servicio o tecnología descrito en el mismo. El lector se compromete y queda obligado a usar la información contenida en el mismo para su propio uso y no para ningún otro. Telefónica Tech no será responsable de ninguna pérdida o daño que se derive del uso de la información contenida en el presente documento o de cualquier error u omisión del documento o por el uso incorrecto del producto, servicio o tecnología. El uso del producto, servicio o tecnología descrito en el presente.